

The following article is a step-by-step methodology formula for designing a SOC Homelab network from complete scratch. In my personal homelab, the first step I encountered after defining my organization and the threat it was facing was the network design process. As I was mulling over network segments, firewalls, and NICs, I realized that the entire homelab and security architecture depends on the design of the network. As a result, I figured it would be worth the time to create a flexible, easily reproducible step-by-step methodology to internalize when confronted with the task of securing any company, big or small.

Step 1-2: Defining the Organization and Building the Threat Model

Since this blog post doesn't encompass the entirety of home-lab design, I will keep all of the auxiliary steps that facilitate instead of participating directly in the network design process to a brief size. The first and most impactful step before designing a network is defining the organization and the threats it will face. The size and type of organization influences the number of segments you have on the network, the amount and variety of security architecture you will need, as well as any additional quirks it will need to conform to the unique business focus (For instance, my choice of a manufacturing company includes OT considerations that the average corporate customer would not need). Moreover, the threat model you build will later model the attack campaigns you perform on the home lab.

Before a single line of network design is even mapped out, it is helpful to answer the following questions to craft an introductory statement.

- What does your company do?
- How big is it?
- What industry?
- What are you protecting, what are the “crown jewels”?

To build the threat model, it is helpful to answer the following questions:

- Who are they?
- What do they want?
- How would they get it?

Step 3: Designing Network Segments

Each segment in a network dictates the level of trust ascribed to that part of the network. Systems that, by default, should not trust each other should be in different network segments. Table 1 shows the standard segments that could be seen in an industrial SOC lab:

Table 1: Basic Segment Template for Industrial SOC Lab

Segment	What's in it	Trust Level
---------	--------------	-------------

Corporate/IT	Active Directory (AD), workstations, file shares, email	Medium: Authentication Users
SOC/Monitoring	SIEM, log collectors, dashboards	High: Security Team
OT/ICS	PLCs, HMIs, engineering workstations	High: Security Team
DMZ	Externally-exposed services	Low (Assumed Compromise)
Attacker	Kali, attack tools	None
Malware Analysis	Sandbox VMs, RE tools	Zero (Isolated)

When you have your network segments laid out, the next step is to figure out how they will connect and incorporate the security architecture of the lab. To do so, it is helpful to establish some design rules that you will structure your network around.

1. Every segment gets its own subnet
2. A firewall sits between every segment
3. Default deny between segments
4. The monitoring segment sees everything but is reachable by nothing
5. The malware analysis segment routes to nothing

Step 4: Allocate IP Addresses

With the segments established and connections mapped out, you can now design the IP scheme. Not only do IP's perform their primary job of routing on the internet, they also work as a readability aid when analyzing logs, enabling you to identify traffic from each segment.

There are several approaches that you can take with a homelab, and which one you choose depends on whether you are going for a realistic real-world environment or a homelab environment. The following three IP schemes offer this choice:

1. Scheme 1: Segment in the third octet. Easy readability, yet no room for sub-segments.
 - a. 10.0.1.0/24 - Corporate
 - b. 10.0.2.0/24 - SOC/Monitoring
 - c. and etc...
2. Scheme 2: Segment in the second octet. Room to grow, room for sub-segmentation.
 - a. 10.1.0.0/24 - Corporate
 - b. 10.2.0.0/24 - SOC/Monitoring

3. Scheme C: Private address range. Smaller private ranges often used for homelabs, but not applicable to real enterprise networks.
 - a. 192.168.10.0/24 - Corporate
 - b. 192.168.20.0/24 - SOC/Monitoring

For IP address allocation on a homelab network, static IPs are used for deterministic log analysis. Moreover, .1 on every subnet is always reserved for the gateway.

Step 5: Monitoring Infrastructure

The network layer is now built, with segments mapped and IPs allocated. The next step is the security layer, which in the case of SOC involves the placing of monitoring infrastructure. The key question for this task is: can the monitoring platform see traffic on the segment, and how?

Table 2 organizes the placement of 4 interfaces for SOC infrastructure (Security Onion, in the case of my SOC homelab). The placement was made with the following two considerations: monitor interfaces have no IP addresses and each segment that needs to be monitored gets an interface.

Table 2: Security Onion Placement

Interface	Type	Network	Has IP?	Purpose
NIC 1	Management	SOC/Monitoring Subnet	Yes	Access web UI ,manage the box
NIC 2	Monitoring	Corporate	No	Passive capture of IT traffic
NIC 3	Monitoring	OT/ICS	No	Passive capture of OT traffic
NIC 4	Monitoring	DMZ	No	Passive capture of exposed services

Note: An extra security layer can be added with the use of a firewall as a sensor. If you're running pfSense between segments, it sees all of the traffic between them. By forwarding its logs to Security Onion, you add a visibility layer aside from the existing network tap and host logs.

Step 6: Traffic Flows and Firewall Rules

This step implements access control within your lab and controls what each segment should have access to and why. Table 3 provides an example of common flows that are seen in an industrial lab.

Table 3: Common Flows in an Industrial Lab

From	To	Port/Protocol	Why
OT	SOC	Syslog	OT logs forwarded for monitoring
Corporate	SOC	Syslog	AD and workstation logs forwarded for monitoring
Corporate	OT	DENIED	(From Purdue Model): IT never connects with OT
Attacker	Corporate	Any (during campaign)	Simulated attack traffic
Attacker	ICS	Any (during campaign)	Simulated ICS attack
Malware Analysis	Anything	DENIED	Isolation for Malware Analysis segment
SOC	Corporate	SSH,RDP	Incident response

With the flows mapped out, that concludes the network design process. To be extra thorough, it would be smart to start planning an attack surface as an optional step 7. This would include plans for each attack campaign you will run in the lab. The output for this step would be one kill chain map per campaign and ATT&CK technique IDs for each step.